

A governança de segurança é um aspecto crítico da postura geral de segurança de uma organização, fornecendo uma estrutura que orienta o gerenciamento de riscos de cibersegurança. Ela envolve o desenvolvimento, a implementação e a manutenção de políticas, procedimentos, normas e diretrizes para proteger os ativos de informação e a infraestrutura técnica. A governança de segurança engloba as funções e responsabilidades de várias partes interessadas, enfatizando a necessidade de uma cultura de conscientização sobre a segurança em toda a organização. As estruturas de governança devem gerenciar e manter a conformidade com as leis, os regulamentos e as obrigações contratuais relevantes, ao mesmo tempo em que apoiam os objetivos estratégicos da organização. A governança de segurança eficaz também envolve monitoramento e melhoria contínuos para se adaptar às ameaças em evolução e às mudanças no ambiente de negócios e regulatório.

Nesta lição, você vai fazer o seguinte:

- Identificar a diferença entre políticas, procedimentos, normas e diretrizes.
- Aprender mais sobre as complexidades do ambiente legal que afetam as operações de segurança.
- Explorar conceitos de governança e o papel da liderança nas operações de segurança.
- Entender a importância das práticas de gerenciamento de mudanças.
- Explorar o papel da automação e orquestração nas operações de segurança.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Políticas, normas e procedimentos são três componentes essenciais que formam a base do programa de segurança de uma organização. As políticas são documentos oficiais de alto nível que definem o compromisso de segurança da organização. As normas são mais específicas do que as políticas e detalham os métodos usados para implementar os requisitos técnicos e processuais. Os procedimentos são instruções detalhadas, passo a passo, que descrevem como concluir tarefas específicas e se alinhar aos requisitos estabelecidos nas normas. Os procedimentos fornecem instruções claras para que os indivíduos desempenhem suas funções de forma consistente, segura e eficiente.

Objetivos abordados no exame:

- 5.1 Resumir os elementos de uma governança de segurança eficaz.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

As [[políticas]] organizacionais são fundamentais para estabelecer uma governança eficaz e garantir a conformidade da organização. Elas formam a estrutura para as operações, a tomada de decisões e os comportamentos, estabelecendo regras para uma cultura corporativa ética e em conformidade. A governança se refere aos processos usados para dirigir e controlar uma organização, incluindo os processos de tomada de decisões e gerenciamento de riscos. As políticas são resultado da governança. Elas estabelecem as regras que estruturam os processos de tomada de decisões, mitigação de riscos, equidade e transparência. Também definem expectativas de desempenho, alinham a organização em torno de objetivos comuns, evitam condutas impróprias e removem pontos de ineficiência.

A conformidade se refere ao cumprimento dos regulamentos, políticas, normas e leis relevantes para sua operação por parte de uma organização. As políticas organizacionais são fundamentais para garantir a conformidade e integram os requisitos legais e regulatórios às operações diárias. As políticas definem as regras e os procedimentos para manter a conformidade e descrevem as consequências da não conformidade.

Por exemplo, uma organização pode ter uma política de privacidade de dados que explica como será mantida a conformidade com as leis relevantes para proteger os dados do cliente. A política detalha práticas de coleta, armazenamento, processamento e compartilhamento de dados, incluindo as responsabilidades dos funcionários, para garantir que todos os membros da organização entendam e cumpram as regras. As políticas organizacionais ajudam a facilitar as avaliações de conformidade por meio de auditorias internas e externas, pois fornecem um roteiro que os auditores seguem para determinar se uma organização está operando como afirma e satisfaz suas obrigações regulatórias.

Políticas organizacionais comuns

- [[Política de Uso Aceitável (AUP)]]: Esta política define as formas aceitáveis de utilização dos sistemas de rede e computadores, especificando o que é considerado comportamento aceitável por parte dos usuários. As AUPs geralmente abordam o comportamento de navegação, o conteúdo apropriado, os downloads de software e o manuseio de informações sensíveis. O objetivo de uma AUP é garantir que os usuários não se envolvam em atividades que possam prejudicar a organização ou seus recursos. Além disso, a AUP deve especificar as consequências da não conformidade, incluindo detalhes sobre como a conformidade é monitorada, e exigir que os funcionários reconheçam sua compreensão das regras da AUP por meio da assinatura.
- [[Políticas de Segurança da Informação]]: São políticas criadas por uma organização para garantir que todos os usuários de tecnologia da informação cumpram as regras e diretrizes relacionadas à segurança das informações

armazenadas no ambiente ou sob a esfera de autoridade da organização.

- [[Planos de Continuidade de Negócios e Continuidade de Operações (COOP)]]: As políticas de continuidade de negócios e COOP têm foco nos processos críticos que devem permanecer operacionais durante e após uma interrupção significativa, como um desastre natural ou um ataque cibernético.
- [[Recuperação de Desastres]]: Essas políticas detalham as etapas necessárias para se recuperar de um evento catastrófico, como um desastre natural, falha grave de hardware ou uma violação significativa de segurança. O objetivo é restaurar as operações da forma mais rápida e eficiente possível.
- **Resposta a incidentes**: esta política descreve os processos a serem seguidos após uma violação de segurança ou ciberataque. Ela detalha as etapas para identificar, investigar, controlar e mitigar o impacto dos incidentes, incluindo procedimentos para comunicá-los a fontes internas e externas.
- [[Ciclo de Vida do Desenvolvimento de Software (SDLC)]]: As políticas de SDLC regulam o desenvolvimento de software dentro de uma organização. Elas fornecem um plano estruturado detalhando os estágios de desenvolvimento, desde a análise inicial de requisitos até a manutenção após a implantação. Isso garante que todos os programas de software produzidos atendam às normas de eficiência, confiabilidade e segurança da organização.
- **Gerenciamento de mudanças**: as políticas de gerenciamento de mudanças descrevem como as modificações nos sistemas e software de TI são solicitadas, revisadas, aprovadas e implementadas, incluindo todos os requisitos de documentação.

As diretrizes

[[Diretrizes]] descrevem recomendações que orientam as ações em uma determinada função ou departamento. Elas são mais flexíveis do que as políticas e permitem maior autonomia para os indivíduos que as implementam. As diretrizes fornecem as práticas recomendadas e sugestões para atingir as metas e concluir as tarefas de forma eficaz. Elas ajudam as pessoas a entender as etapas necessárias para cumprir uma política ou melhorar a eficácia.

Um exemplo de diretriz são as práticas de suporte de um help desk relacionadas ao uso de e-mail para responder a solicitações de suporte dos funcionários. A diretriz pode recomendar a linguagem, o tom ou os tempos de resposta específicos, mas permite flexibilidade dependendo das circunstâncias da solicitação. Embora tanto as políticas quanto as diretrizes funcionem para orientar as ações e os comportamentos dos funcionários, as políticas são obrigatórias e definem regras rígidas, enquanto as diretrizes fornecem recomendações e permitem mais julgamento e análise individuais. A revisão regular das diretrizes é importante para garantir que elas permaneçam práticas e relevantes. As avaliações e atualizações periódicas das diretrizes permitem que as organizações as adaptem às novas tecnologias, às operações do negócio, às ameaças emergentes e às normas em evolução do setor.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Resumo

Vamos estruturar a governança de cibersegurança separando regras estritas de recomendações adaptáveis.

Políticas (O rigor técnico e legal)

São regras absolutas e obrigatórias. Garantem governança, mitigam riscos e asseguram a conformidade legal da organização. A violação resulta em sanções diretas. Tipos essenciais:

- **AUP (Política de Uso Aceitável):** Comportamento exigido dos usuários nos sistemas. Requer assinatura de concordância.
- **Segurança da Informação:** Proteção técnica de dados e ativos contra acesso não autorizado.
- **Continuidade (BCP/COOP):** Manutenção de processos críticos do negócio durante crises.
- **Recuperação de Desastres:** Passos técnicos para restaurar a infraestrutura de TI após catástrofes.
- **Resposta a Incidentes:** Protocolo exato para investigar, conter e mitigar ciberataques.
- **SDLC (Ciclo de Vida do Desenvolvimento):** Exigências estruturadas de segurança na criação de software.
- **Gerenciamento de Mudanças:** Controle rígido e documentado sobre qualquer modificação nos sistemas de TI.

Diretrizes (A flexibilidade operacional)

São melhores práticas e recomendações. Permitem autonomia e adaptação do profissional para cumprir a política da forma mais eficaz. Requerem atualizações constantes para lidar com novas ameaças tecnológicas.

Exemplo Prático

Imagine a operação de maquinário pesado industrial.

A **Política** dita: "A máquina deve ser desligada fisicamente da rede elétrica antes da manutenção". É inegociável; o descumprimento está fundamentalmente errado e gera demissão.

A **Diretriz** sugere: "Inicie a lubrificação pelo painel esquerdo para economizar tempo". É a prática recomendada, mas o mecânico tem autonomia para alterar a ordem conforme a situação local exigir.

As políticas e diretrizes estabelecem uma estrutura para comportamentos. [[Procedimentos]] definem instruções passo a passo e listas de verificação para garantir que uma tarefa seja realizada de acordo com a política estabelecida.

Gerenciamento de pessoal

O gerenciamento de identidade e acesso (IAM) envolve procedimentos e tecnologias de TI/segurança e políticas de Recursos Humanos (RH). As políticas de gerenciamento de pessoal são aplicadas em três fases:

- **Recrutamento (contratação):** localizar e selecionar pessoas para trabalharem em cargos específicos. Aqui, questões de segurança incluem avaliar candidatos e realizar verificação de antecedentes.
- **Operação (funcionamento):** frequentemente, é o departamento de RH que gerencia a comunicação de políticas e treinamentos para os colaboradores (embora possa haver um departamento separado de treinamento e desenvolvimento pessoal em organizações de maior porte). Por isso, é crucial que os gerentes de RH elaborem programas de treinamento que transmitam a importância da segurança aos funcionários.
- **Desligamento ou Separação (demissão ou aposentadoria):** seja o desligamento do colaborador voluntário ou involuntário, esse é um processo delicado, com diversas implicações de segurança.

Verificações de antecedentes

Uma verificação de antecedentes determina basicamente se uma pessoa é quem diz ser e se não está ocultando atividades criminosas, falência ou conexões que a tornariam inadequada ou arriscada. Os funcionários que trabalham em ambientes de alta confidencialidade ou com acesso a transações de alto valor obviamente precisarão estar sujeitos a um maior grau de análise. Para alguns cargos, especialmente cargos federais que exigem uma autorização de segurança, as verificações de antecedentes são obrigatórias. Algumas verificações de antecedentes são realizadas internamente, enquanto outras são feitas por um fornecedor externo.

Integração

No âmbito de RH, o `[[onboarding]]` é o processo de recepção e integração de um novo colaborador à organização. O mesmo tipo de princípio se aplica à contratação de novos fornecedores ou prestadores de serviços. Alguns dos mesmos processos e verificações são usados na criação de contas de clientes e convidados.

Como parte da integração, as funções de TI e RH trabalharão juntas para criar uma conta de usuário com acesso ao sistema de computador, atribuir os privilégios apropriados e garantir que as credenciais da conta sejam conhecidas apenas pelo usuário válido. Essas funções devem ser integradas para evitar a criação de vulnerabilidades de configuração acidentais, como o setor de TI criar uma conta para um funcionário que não foi de fato contratado.

Algumas das outras tarefas e processos envolvidos na integração são:

- **Transmissão segura de credenciais:** criar e enviar uma senha inicial ou emitir um cartão inteligente com segurança. O processo precisa de proteção contra funcionários administrativos desonestos. Contas recém-criadas com senhas simples ou padrão são um backdoor facilmente explorável.
- **Alocação de ativos:** fornecer computadores ou dispositivos móveis para o usuário ou concordar que o usuário possa trazer seus próprios dispositivos.
- **Treinamento/políticas:** agendar a conscientização de segurança apropriada e treinamento e certificação relevantes à função.

Nota:

A automação de IAM pode agilizar a integração automatizando as tarefas de gerenciamento de provisionamento e acesso associadas aos novos funcionários. Ela permite a criação e configuração automatizadas de contas de usuário, atribuição de privilégios de acesso apropriados com base em funções e políticas de acesso estabelecidas, bem como

integração com sistemas de RH para sincronização eficiente de dados de novos funcionários. A automação de IAM reduz o esforço manual, garante consistência e melhora a segurança graças à aplicação de controles de acesso padronizados, acelerando a integração e mantendo práticas de segurança fortes.

Playbooks

Os playbooks (manuais) são essenciais para estabelecer e manter os procedimentos organizacionais, pois estabelecem um repositório central de estratégias e táticas bem definidas e padronizadas. Eles orientam o pessoal para garantir consistência nas operações e melhorar a qualidade e a eficácia.

Os playbooks facilitam o compartilhamento de conhecimento e a continuidade quando funcionários assumem novas funções ou deixam a organização. Eles também mitigam os riscos ao documentar procedimentos críticos e preservar o conhecimento institucional. Os playbooks ajudam os novos membros da equipe a aprender rapidamente os processos estabelecidos e servem de referência para as tarefas dos membros antigos.

Além disso, os playbooks funcionam como uma ferramenta para a garantia de qualidade e melhoria contínua. Definir claramente os processos e as práticas recomendadas para lidar com eles facilita a identificação e melhoria das áreas problemáticas. Com os playbooks, as organizações podem monitorar o uso e a eficácia dos procedimentos ao longo do tempo e modificá-los conforme necessário para promover um ambiente de aprendizado e desenvolvimento contínuos.

Mais significativamente, os playbooks são essenciais na resposta a incidentes e no gerenciamento de crises, pois detalham procedimentos de emergência e planos de contingência vitais para orientar as atividades durante uma emergência ou crise. Os playbooks ajudam as equipes de resposta a incidentes a tomar decisões rápidas e trabalhar de forma mais eficaz sob estresse, levando a operações mais resilientes e reduzindo a probabilidade e o impacto de grandes incidentes de segurança.

Nota:

Diversos guias de boas práticas e frameworks estão disponíveis para auxiliar no desenvolvimento de playbooks, como o framework MITRE ATT&CK (<https://attack.mitre.org> (<https://attack.mitre.org>)) e a NIST Special Publication 800-61 (<https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final> (<https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final>)).

Gerenciamento de mudanças

A implementação de mudanças deve ser planejada com cuidado, considerando como a alteração afetará componentes dependentes. Em relação à maioria das mudanças grandes ou significativas, as organizações devem tentar primeiro testar a mudança. Toda mudança deve ser acompanhada por um plano de reversão (ou remediação), caso ela tenha consequências imprevistas ou prejudiciais. Mudanças também devem ser programadas de modo ponderado em relação às chances de causar inatividade de sistemas ou outros impactos negativos no fluxo de trabalho das unidades de negócios que dependem do sistema de TI que está sendo modificado. A maioria das redes tem uma janela de manutenção programada para inatividade autorizada. Quando a mudança tiver sido implementada, seu impacto deverá ser avaliado e o processo revisado e documentado para identificar todos os resultados que possam ajudar em futuros projetos de gestão de mudança.

Desligamento

O offboarding garante que um colaborador deixe a empresa de forma adequada, incluindo uma entrevista de desligamento para obtenção de feedback. O offboarding também é aplicado quando um projeto com contratados ou terceiros chega ao fim. Em termos de segurança, existem vários processos que precisam ser concluídos:

- **Gerenciamento de contas:** desativar a conta e os privilégios do usuário. Lembre-se de que quaisquer ativos de informação criados ou gerenciados pelo funcionário, mas de propriedade da empresa, devem continuar acessíveis (em termos de chaves de criptografia ou arquivos protegidos por senha).
- **Ativos da empresa:** recuperar dispositivos móveis, chaves, cartões inteligentes, mídia USB, etc. O funcionário precisará confirmar (e, em alguns casos, provar) que não reteve cópias de quaisquer ativos de informações.
- **Ativos pessoais:** eliminar os dados e aplicativos da empresa nos dispositivos de propriedade do funcionário. O funcionário também pode ter permissão para reter alguns ativos de informações (como emails pessoais ou informações de contato), dependendo das políticas em vigor.

A saída de alguns tipos de funcionários deve desencadear processos adicionais para proteger novamente os sistemas de rede. Por exemplo, funcionários com conhecimento detalhado dos sistemas e procedimentos de segurança e com acesso a credenciais de contas compartilhadas ou genéricas. Essas credenciais devem ser alteradas imediatamente.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Padrões]] definem o resultado esperado de uma tarefa, como um determinado estado de configuração para um servidor ou uma baseline de desempenho para um serviço. A seleção e a aplicação de normas dentro de uma organização se concentram em vários elementos dinâmicos, como requisitos regulamentares, necessidades específicas do negócio, estratégias de gerenciamento de riscos, práticas do setor e expectativas das partes interessadas.

Os requisitos regulamentares são o principal motivador da adoção de normas. As diferenças operacionais entre as organizações determinam diferentes requisitos legais e regulamentos de segurança, privacidade e proteção de dados. Esses requisitos geralmente exigem a implementação de normas específicas ou o uso de diretrizes para alcançar a conformidade. O setor de saúde nos Estados Unidos é um exemplo clássico em que os provedores devem cumprir as rigorosas normas de proteção de dados e privacidade estabelecidas pela Health Insurance Portability and Accountability Act (HIPAA).

Dependendo da natureza das operações, base de clientes ou dependências tecnológicas, cada organização deve adotar normas que atendam especificamente às suas necessidades. Por exemplo, as organizações que utilizam muitas transações com cartão de crédito adotarão a norma PCI DSS para proteger o ambiente de dados do titular do cartão (CDE). Da mesma forma, as organizações dependentes da nuvem geralmente preferem adotar a ISO/IEC 27017 e a ISO/IEC 27018 para garantir operações seguras e protegidas na nuvem.

As estratégias de gestão de riscos auxiliam as organizações a enfatizar a necessidade de padrões adequados. As normas ajudam a identificar, avaliar e gerenciar riscos e fortalecem a resiliência da organização contra incidentes de segurança ou violações de dados. A ISO/IEC 27001, por exemplo, fornece uma estrutura abrangente para um sistema de gerenciamento de segurança da informação (ISMS) projetado para ajudar as organizações a gerenciar efetivamente os riscos de segurança. A adesão às práticas recomendadas do setor também influencia a adoção de normas. A conformidade com normas amplamente aceitas e testadas demonstra o compromisso de uma organização em manter altos níveis de segurança e proteção de dados, de modo a reforçar a reputação da organização e criar confiança com clientes e parceiros. As expectativas das partes interessadas (como clientes, parceiros, fornecedores, investidores, conselhos executivos etc.) também influenciam significativamente a escolha das normas. As partes interessadas veem a adesão às normas reconhecidas como uma afirmação da dedicação da organização à qualidade, segurança e confiabilidade.

A escolha das normas não deve ser uma decisão processual, mas sim estratégica. A seleção das normas envolve um equilíbrio cuidadoso entre os requisitos legais e regulamentares, as necessidades específicas do negócio, os protocolos de gerenciamento de riscos, as práticas recomendadas do setor e as expectativas das partes interessadas. A adoção das normas afeta a forma como uma empresa opera, e a seleção das normas apropriadas ajuda a organização a funcionar de forma mais eficaz. Por outro lado, adotar as normas erradas ou não planejar a implementação de forma adequada pode ter consequências negativas graves.

Normas do setor

As normas comuns do setor usadas por organizações públicas e privadas incluem:

- **ISO/IEC 27001**: uma norma internacional que fornece uma estrutura de sistema de gerenciamento de segurança de informações (ISMS) para garantir que controles de segurança adequados e proporcionais estejam em vigor.
- **ISO/IEC 27002**: esta é uma norma complementar à ISO 27001 e fornece orientação detalhada sobre controles específicos a serem incluídos em um ISMS.
- **ISO/IEC 27017**: uma extensão da ISO 27001 específica para serviços em nuvem.
- **ISO/IEC 27018**: outra adição à ISO 27001, específica para proteger informações de identificação pessoal (PII) em nuvens públicas.
- **Publicação especial 800-63 do NIST (National Institute of Standards and Technology)**: uma norma do governo dos EUA para diretrizes de identidade digital, incluindo requisitos de senha e controle de acesso.
- **PCI DSS (Payment Card Industry Data Security Standard)**: norma para organizações que lidam com cartões de crédito das principais bandeiras, incluindo requisitos para proteger os dados do titular do cartão.
- **FIPS (Federal Information Processing Standards)**: normas e diretrizes desenvolvidas pelo NIST para sistemas de computadores federais nos Estados Unidos. Elas especificam requisitos para criptografia.

As normas comuns do setor, como essas, desempenham um papel significativo na auditoria, dado que servem de referência para avaliar a conformidade organizacional e as práticas de segurança. Normas como ISO 27001, NIST SP800-63, PCI DSS e FIPS fornecem detalhes e requisitos abrangentes para a segurança das informações, o gerenciamento de riscos, a proteção de dados e a privacidade. A auditoria em relação a essas normas ajuda as organizações a avaliar sua adesão às práticas recomendadas, identificar lacunas ou vulnerabilidades e demonstrar seu compromisso em manter um ambiente seguro e compatível.

Normas internas

As organizações também estabelecem normas internas para garantir a segurança e integridade das operações e proteger recursos valiosos, como dados, propriedade intelectual e hardware. As normas internas fornecem descrições consistentes para definir e gerenciar práticas organizacionais importantes. As normas diferem das políticas de algumas maneiras. De modo simplista, as normas se concentram na implementação, enquanto as políticas se concentram nas práticas de negócios.

As normas de senha se referem aos requisitos técnicos específicos necessários para projetar e implementar sistemas, incluindo como as senhas são gerenciadas dentro desses sistemas para garantir que diferentes sistemas possam interagir e usar métodos consistentes de manipulação de senhas.

- **Algoritmos de hash:** define requisitos para as funções hash usadas para armazenar senhas.
- **Salting de Senha:** Define os métodos utilizados para proteger hashes de senhas contra ataques com rainbow tables.
- **Transmissão segura de senhas:** define os métodos para transmissão segura de senhas, incluindo detalhes sobre os conjuntos de cifras apropriados.
- **Redefinição de Senha:** Define métodos adequados de verificação de identidade para proteger solicitações de redefinição de senha contra exploração.
- **Gerenciadores de Senhas:** Define os requisitos para gerenciadores de senhas que as organizações podem optar por adotar.

As normas de controle de acesso garantem que apenas indivíduos autorizados possam acessar os sistemas e dados de que precisam para realizar seu trabalho, a fim de proteger informações sensíveis e ajudar a evitar alterações ou danos acidentais. Os padrões de controle de acesso desenvolvidos internamente geralmente incluem os seguintes elementos:

- **Modelos de controle de acesso:** definem modelos de acesso apropriados para diferentes casos de uso. Alguns exemplos incluem controle de acesso baseado em função (RBAC), controle de acesso discricionário (DAC) e controle de acesso obrigatório (MAC).
- **Verificação de identidade do usuário:** define métodos aceitáveis para verificar identidades antes de conceder acesso. Alguns exemplos são senhas simples, tokens de segurança e dados biométricos.
- **Gerenciamento de privilégios:** define os métodos de gerenciamento de privilégios para garantir que os usuários tenham o acesso mínimo necessário.
- **Protocolos de autenticação:** define protocolos de autenticação aceitáveis específicos, como Kerberos, OAuth ou SAML.
- **Gerenciamento de sessão:** define práticas de gerenciamento de sessão permitidas, incluindo requisitos para tempo limite de sessão, geração e transmissão seguras de cookies de sessão e outros requisitos semelhantes.

- **Trilhas de auditoria:** define recursos de auditoria obrigatórios projetados para auxiliar na identificação e investigação de incidentes de segurança.

As normas de segurança física protegem datacenters, salas de computadores, armários de fiação, cabeamento, hardware e infraestruturas, bem como o ambiente de TI e as pessoas que os usam e mantêm. Alguns exemplos incluem:

- **Segurança predial:** métodos para proteger instalações, incluindo sistemas de acesso por cartão, vigilância de CFTV e pessoal de segurança.
- **Segurança de Estações de Trabalho:** Padrões para a proteção física de laptops ou outros dispositivos portáteis.
- **Segurança de Datacenters e Salas de Servidores:** Define os requisitos para acesso por crachá, leituras biométricas, registros de entrada e saída e acompanhamento de visitantes.
- **Descarte de Equipamentos:** Define os requisitos para o descarte seguro (ou reaproveitamento) de equipamentos, visando garantir que dados sensíveis sejam irrecuperáveis.
- **Gestão de Visitantes:** Define os requisitos para o gerenciamento de visitantes, como procedimentos de registro de entrada e saída, crachás de visitante e necessidades de acompanhamento durante o acesso.

A criptografia protege os dados contra acesso não autorizado e é vital para a proteção dos dados em repouso (dados armazenados) e em trânsito (dados transmitidos). Os padrões de criptografia identificam os conjuntos de cifras aceitáveis e os procedimentos esperados, ambos necessários para garantir que os dados permaneçam protegidos.

- **Algoritmos de Criptografia:** Define os algoritmos de criptografia permitidos, como o AES (Advanced Encryption Standard) para criptografia simétrica ou ECC para criptografia assimétrica.
- **Tamanho de Chave** — Define os comprimentos mínimos de chave permitidos para diferentes tipos de criptografia.
- **Gestão de Chaves:** Define como as chaves são geradas, distribuídas, armazenadas e substituídas. Muitas vezes, inclui requisitos para usar sistemas de gerenciamento de chaves seguros, procedimentos para alterar regularmente as chaves e para revogá-las se forem comprometidas.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Resumo

As normas (ou padrões) estabelecem o resultado técnico exato e inegociável que um sistema, configuração ou processo deve alcançar. Se a política da empresa define a regra de negócio e o objetivo de segurança, a norma define a especificação técnica de como isso será implementado. Em cibersegurança, não há espaço para subjetividade: um sistema atende à norma ou está vulnerável e fora de conformidade.

Para compreendermos o texto, podemos dividir o conceito em duas frentes de aplicação:

1. Normas Externas (Setoriais)

São os frameworks e padrões globais exigidos por leis, regulações ou contratos de negócios. Elas formam a base para auditorias e garantem que a empresa atue de forma segura perante o mercado.

- **ISO/IEC 27001 e 27002:** Estabelecem a estrutura e os controles para a construção de um Sistema de Gestão de Segurança da Informação (SGSI).
- **ISO/IEC 27017 e 27018:** São extensões focadas especificamente na segurança e na privacidade de dados hospedados em computação em nuvem.
- **NIST SP 800-63:** Dita os requisitos técnicos profundos sobre identidade digital, senhas e autenticação.
- **PCI DSS:** O padrão obrigatório para qualquer infraestrutura que armazene, processe ou transmita dados de cartões de crédito.
- **FIPS:** Normas governamentais que especificam os requisitos matemáticos e técnicos rigorosos para o uso de algoritmos de criptografia.

2. Normas Internas

São os documentos técnicos criados pelos próprios times de segurança para garantir a uniformidade dentro da infraestrutura da organização. Elas ditam parâmetros estritos em quatro áreas principais abordadas no texto:

- **Senhas:** Exigem algoritmos de hash aprovados, o uso de *salting* para frustrar quebras de criptografia, regras para gerenciadores de senhas e transmissão segura.
- **Controle de Acesso:** Definem os modelos arquitetônicos (MAC, DAC, RBAC), os protocolos de autenticação (como Kerberos ou SAML), a gestão de privilégios e os tempos exatos para o *timeout* de uma sessão.
- **Segurança Física:** Parametrizam desde a vigilância (CFTV) e controles de acesso por crachás ou biometria em datacenters, até o método técnico obrigatório para destruição e descarte de discos rígidos antigos.
- **Criptografia:** Determinam quais cifras são permitidas (exemplo: AES-256), o tamanho mínimo das chaves criptográficas e todo o ciclo de vida envolvido na geração, armazenamento e revogação dessas chaves.

O Conceito na Prática

Para ilustrar a diferença entre uma política e uma norma, considere a manutenção na aviação comercial. A **política** de segurança da companhia aérea dita: "Aeronaves só podem operar se seus componentes vitais estiverem em condições seguras". A **norma** técnica estabelece: "Os pneus do trem de pouso principal devem ser calibrados com exatos 200 PSI de nitrogênio puro". A norma é o parâmetro técnico mensurável de implementação; se a aferição indicar 190 PSI, o procedimento está errado e a aeronave não voa.

Os comitês de governança garantem que as organizações cumpram todas as leis e regulamentos de cibersegurança aplicáveis para protegê-las contra responsabilidade legal. O comitê de governança deve abordar essas considerações externas no plano estratégico da organização.

Ele deve administrar muitos riscos legais, como requisitos de conformidade regulatória, obrigações contratuais, leis de divulgação pública, responsabilidade por violação de dados, leis de privacidade, proteção de propriedade intelectual, contratos de licenciamento e muitos outros. Os comitês de governança de cibersegurança devem interpretar esses requisitos legais e aplicá-los em controles operacionais para evitar problemas legais, agir de forma ética e proteger a organização.

Os principais guias de configuração, estruturas e benchmarks podem ser usados para demonstrar a conformidade com os requisitos legais/regulamentares de um país ou com regulamentos específicos do setor. *Due diligence* é um termo jurídico que significa que as pessoas responsáveis não foram negligentes no cumprimento de suas obrigações. A negligência pode criar responsabilidades criminais e civis. Muitos países já promulgaram leis que criminalizam a negligência no gerenciamento de informações. Nos Estados Unidos, por exemplo, a [[Lei Sarbanes-Oxley (SOX)]] exige a implementação de avaliações de risco, controles internos e procedimentos de auditoria. A Lei de Segurança de Computadores (1987) exige que as agências federais desenvolvam políticas de segurança para sistemas de computador que processam informações confidenciais. Em 2002, a Lei Federal de Gerenciamento de Segurança da Informação (Federal Information Security Management Act, FISMA) foi introduzida para governar a segurança dos dados processados por agências do governo federal.

Nota:

Alguns regulamentos têm requisitos específicos de controle de cibersegurança; outros simplesmente exigem o cumprimento das "práticas recomendadas", como representadas por um setor ou estrutura internacional específicos. Pode ser necessário comparar diferentes estruturas do setor, como NIST e ISO 27K, se um órgão regulador especificar o uso de uma mas não de outra. Por outro lado, o uso de estruturas pode não ser obrigatório, mas os auditores provavelmente esperam que elas estejam em vigor como demonstração de um programa de segurança forte e competente.

Direito gobal

Com os sistemas de informação se tornando cada vez mais interconectados globalmente, muitos países promulgaram leis com alcance mais amplo e internacional. Alguns exemplos incluem o Regulamento Geral sobre a Proteção de Dados (RGPD) e a Lei de Privacidade do Consumidor da Califórnia (CCPA), que atuam para proteger a privacidade dos constituintes associados a cada lei respectiva, independentemente dos limites geopolíticos.

Dados pessoais e Regulamento Geral sobre a Proteção de Dados (RGPD)

Quando alguns tipos de legislação abordam o dever de diligência de cibersegurança, outros se concentram total ou parcialmente na segurança da informação, pois afeta a privacidade ou os dados pessoais. A privacidade é um conceito diferenciado e exige que a coleta e o processamento de informações pessoais sejam seguros e justos. A justiça e o direito à privacidade, conforme estabelecido por regulamentos como o [[Regulamento Geral de Proteção de Dados (GDPR)]] da União Europeia, significam que dados pessoais não podem ser coletados, processados ou mantidos sem o consentimento informado do titular, salvo em casos de interesse público ou outras obrigações legais que prevaleçam.

Consentimento informado significa que os dados devem ser coletados e processados apenas para a finalidade declarada, e essa finalidade deve ser claramente descrita ao usuário em linguagem simples, e não em termos jurídicos.

O GDPR(https://commission.europa.eu/law/law-topic/data-protection/data-protection-eu_en (https://commission.europa.eu/law/law-topic/data-protection/data-protection-eu_en)) concede aos titulares dos dados o direito de retirar o consentimento, assim como de inspecionar, retificar ou apagar os dados mantidos sobre eles. O não cumprimento das regras do RGPD pode resultar em multas incrivelmente altas.

Lei de Privacidade do Consumidor da Califórnia (California Consumer Privacy Act, CCPA)

A CCPA concede aos residentes da Califórnia o direito de saber quais informações pessoais as empresas coletam sobre eles, a finalidade da coleta desses dados e com quem eles são compartilhados. Ela protege os direitos dos residentes da Califórnia de acessar suas informações pessoais, excluí-las ou cancelar sua venda. As organizações devem informar os consumidores sobre as categorias de informações pessoais que coletam e os propósitos para os quais as informações serão usadas. A CCPA se aplica a qualquer organização, independentemente de sua localização, que forneça bens ou serviços a residentes da Califórnia; tenha receita anual bruta superior a US\$ 25 milhões; compre ou venda as informações pessoais de 50.000 ou mais consumidores, residências ou dispositivos; ou obtenha 50% ou mais das receitas anuais da venda de informações pessoais.

Nota:

O blog de Varoni contém uma visão geral útil das leis de privacidade nos Estados Unidos (varonis.com/blog/us-privacy-laws) (<https://www.varonis.com/blog/us-privacy-laws/>)).

Regulamentações e leis nacionais, locais, regionais e setoriais

Muitos países têm leis nacionais para apoiar práticas eficazes de segurança cibernética e proteger os dados dos cidadãos. O escopo e os pormenores dessas leis variam significativamente de um país para outro, mas as organizações devem cumprir as leis em todas as jurisdições onde funcionam.

Alguns exemplos nos Estados Unidos são a Lei de portabilidade e responsabilidade de seguros de saúde (Health Insurance Portability and Accountability Act, HIPAA), a Lei Gramm-Leach-Bliley (GLBA) e a Lei federal de gestão de segurança da informação (Federal Information Security Management Act, FISMA). As leis do Reino Unido incluem a Lei de proteção de dados (Data Protection Act, DPA) e as diretivas sobre Redes e sistemas de informação (Network and Information Systems, NIS), ambas de 2018. O Canadá aplica uma lei de privacidade chamada Lei de proteção de informações pessoais e documentos eletrônicos (Personal Information Protection and Electronic Documents Act, PIPEDA), a Índia regula o setor de TI com a Lei de tecnologia da informação (Information Technology Act), de 2000, e a Austrália aplica a Lei de privacidade (Privacy Act) de 1988. Embora não seja necessário compreender os detalhes de cada uma dessas leis, é importante entender que esse complexo enquadramento legal influencia muito os elementos funcionais de um programa de segurança cibernética.

Embora a maioria das leis de segurança cibernética geralmente tenha um escopo nacional ou internacional devido à natureza global da Internet, também existem leis e regulamentos com um alcance mais local ou regional. Essas leis podem ser específicas de cada estado, província ou mesmo cidade, especialmente em países maiores, como os Estados Unidos. Dois exemplos importantes são a normativa de segurança cibernética do Departamento de serviços financeiros (Department of Financial Services, DFS) de Nova York, seção 500, e o Massachusetts 201 CMR 17.00 (<https://www.mass.gov/regulations/201-CMR-1700-standards-for-the-protection-of-personal-information-of-ma-residents>).

As leis e regulamentos de segurança cibernética específicos da indústria regem como os dados devem ser tratados e protegidos. Vejamos alguns exemplos importantes para mostrar que a segurança cibernética é uma preocupação significativa em todos os setores da indústria e que é protegida por uma complexa matriz de leis a serem observadas pelas operações de segurança cibernética e pela governança organizacional:

Assistência médica

- Lei de portabilidade e responsabilidade de seguros de saúde (Health Insurance Portability and Accountability Act, HIPAA; Estados Unidos)
- Regulamento Geral sobre a Proteção de Dados (RGPD; União Europeia)

Serviços financeiros

- Lei Gramm-Leach-Bliley (GLBA; Estados Unidos)
- Padrão de segurança de dados da indústria de cartões de pagamento (Payment Card Industry Data Security Standard, PCI DSS) (obrigação contratual)

Telecomunicações

- Communications Assistance for Law Enforcement Act (CALEA) (Estados Unidos)

Energia

- North American Electric Reliability Corporation (NERC) (Estados Unidos, Canadá e Baja California Norte, México)

Educação e crianças

- Lei de direitos educacionais e privacidade da família (Family Educational Rights and Privacy Act, FERPA; Estados Unidos)
- Lei de proteção da Internet para crianças (Children's Internet Protection Act, CIPA; Estados Unidos)
- Lei de proteção da privacidade das crianças online (Children's Online Privacy Protection Act, COPPA; Estados Unidos)

Governo

- Lei federal de modernização da segurança da informação (Federal Information Security Modernization Act, FISMA); Estados Unidos)
- Criminal Justice Information Services (CJIS) Security Policy (Estados Unidos)
- Classificações de segurança do governo (Government Security Classifications, GSC; Reino Unido)

As regulamentações de segurança cibernética são regras e diretrizes legais formuladas por governos e órgãos reguladores para proteger as informações e os sistemas digitais contra ameaças cibernéticas. Elas estabelecem padrões para proteger a confidencialidade, integridade e disponibilidade dos dados, especialmente informações confidenciais e pessoais. As regulamentações abrangem diversos recursos, incluindo proteção de dados, segurança de redes e sistemas de informação, notificações sobre violação de dados, verificação de identidade digital e muitos outros. Empresas, agências governamentais, organizações e executivos devem trabalhar de forma responsável para cumprir essas regulamentações ou enfrentar o risco de multas significativas e prisão.

As regulamentações de segurança cibernética visam proteger os direitos de privacidade do consumidor, garantir a segurança do sistema financeiro, defender a estabilidade e a confiabilidade da Internet e da economia digital e proteger a infraestrutura crítica norte-americana contra crimes cibernéticos. A aplicabilidade das regulamentações depende de fatores como o setor em que a organização atua, os tipos de dados com os quais lida e as regiões onde realiza negócios. Aqui estão alguns exemplos importantes, muitos dos quais foram mencionados anteriormente:

- **General Data Protection Regulation (GDPR) (Regulamento Geral sobre a Proteção de Dados, RGPD)**
- **Lei de Privacidade do Consumidor da Califórnia (California Consumer Privacy Act, CCPA)**
- **Health Insurance Portability and Accountability Act (HIPAA)**
- **Lei federal de gerenciamento de segurança da informação (Federal Information Security Management Act, FISMA)**
- **Diretiva de redes e sistemas de informação (Network and Information Systems, NIS)**
- **Certificação do modelo de maturidade em cibersegurança (Cybersecurity Maturity Model Certification, CMMC)**



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Resumo

Vamos dissecar esse conteúdo de forma direta e estruturada. Farei perguntas ao longo do processo para guiar sua compreensão técnica.

O texto trata do **Ambiente Jurídico** na cibersegurança. Em termos técnicos, a tecnologia não opera no vácuo; ela é estritamente subordinada a leis e regulamentações. O não cumprimento dessas regras configura negligência, o que gera sanções civis, criminais e financeiras para a organização.

Aqui estão os pilares exatos que você precisa dominar:

1. Governança e Due Diligence

A alta gestão da empresa tem a obrigação jurídica de provar que fez a sua parte (*Due Diligence* ou "dever de diligência") para proteger os dados.

- Adoção de *frameworks* (como ISO 27001 ou NIST) muitas vezes não é uma lei em si, mas é a prova técnica usada em tribunais para demonstrar que a empresa aplicou as melhores práticas do mercado e não foi negligente.

2. Leis de Escopo Global e Proteção de Privacidade

As legislações modernas não respeitam fronteiras físicas; elas protegem o dado do cidadão onde quer que ele seja processado.

- **GDPR (União Europeia):** Estabelece que o usuário é o dono absoluto de seus dados pessoais. Exige consentimento claro (sem jargões) para a coleta. O usuário pode exigir a exclusão ou alteração dos dados a qualquer momento. A violação gera multas altíssimas.
- **CCPA (Califórnia):** Foca na transparência. O consumidor tem o direito de saber exatamente o que está sendo coletado, por que está sendo coletado e pode proibir a venda de suas informações.

3. Regulamentações Setoriais e Nacionais

Cada mercado atua sob regras específicas e inegociáveis. O texto destaca várias, das quais as mais críticas são:

- **Saúde:** HIPAA (EUA) exige controles técnicos rígidos sobre dados médicos e prontuários.
- **Finanças:** GLBA (lei americana) e PCI DSS (um padrão da indústria imposto por contratos) exigem proteção absoluta de dados bancários e de cartões de crédito.
- **Governo:** FISMA (EUA) dita como agências federais devem proteger seus sistemas.
- **Educação/Menores:** FERPA, COPPA e CIPA são legislações focadas em proteger a privacidade e os dados de crianças e estudantes.

Exemplo Prático (Indústria Automotiva)

Pense na linha de montagem de uma fabricante de veículos. A equipe de engenharia pode criar o motor mais potente do mundo (a equipe de TI construindo uma infraestrutura ágil). No entanto, se o veículo for vendido sem freios ABS, cintos de segurança ou sem passar por testes de impacto, a fabricante será processada e a fábrica interditada. As leis de trânsito e regulamentações de segurança veicular representam o **Ambiente Jurídico**. A cibersegurança é responsável por instalar os "freios e cintos" (criptografia, firewalls, auditorias) para garantir que a empresa possa operar na rodovia (mercado) sem cometer infrações.

As práticas de [[governança]] garantem que as organizações cumpram todas as leis e regulações de cibersegurança aplicáveis, protegendo-as de responsabilidades legais. A governança e a supervisão organizacional devem administrar muitos riscos legais, como requisitos de conformidade regulatória, obrigações contratuais, leis de divulgação pública, responsabilidade por violação de dados, leis de privacidade, proteção de propriedade intelectual e contratos de licenciamento, e interpretar e traduzir esses requisitos legais em controles operacionais para evitar problemas legais, agir de forma ética e proteger a organização.

Monitoramento e revisão

O cenário da cibersegurança está em constante evolução. Consequentemente, as organizações devem garantir que suas políticas, procedimentos, padrões e práticas de conformidade legal de segurança cibernética associadas à conformidade legal e regulatória sejam assiduamente monitoradas, avaliadas e atualizadas. Essas responsabilidades são geralmente administradas de forma colaborativa por diversos grupos para revisar políticas, procedimentos e padrões existentes e garantir sua eficácia em relação às exigências atuais. Auditorias, inspeções e avaliações de rotina são comumente usadas para medir os níveis de conformidade e identificar novos riscos. Os resultados de relatórios de conformidade, mudanças tecnológicas, processos de negócios, leis ou riscos recém-identificados levam a revisões de políticas, procedimentos e padrões. Sessões regulares de treinamento contribuem para informar os funcionários sobre as mudanças nas políticas e garantem a conformidade contínua.

Além disso, as organizações devem manter-se cientes de quaisquer mudanças na legislação de segurança cibernética em suas jurisdições, incluindo leis internacionais, nacionais, regionais ou específicas do setor. O monitoramento e a revisão eficazes de políticas, procedimentos, padrões e práticas de conformidade legal de segurança cibernética são um processo dinâmico e cíclico que requer diligência, previdência e estratégias proativas.

Conselhos de governança

Os [conselhos de governança] são essenciais para assegurar a governança e a supervisão eficazes da segurança em uma organização, pois são responsáveis por definir objetivos estratégicos, políticas e diretrizes para as práticas de segurança e a gestão de riscos. Os conselhos de governança supervisionam a implementação de controles de segurança, trabalham em estreita colaboração com as equipes de gestão de riscos para garantir a conformidade com as leis e regulamentações relevantes e avaliam a eficácia geral do programa de segurança. Os conselhos de governança impulsionam as práticas de segurança em toda a organização por meio de liderança, orientação e responsabilização e garantem que os riscos de segurança sejam identificados e reduzidos de forma eficaz. Os conselhos de governança unem a gestão executiva, os profissionais de segurança e as partes interessadas para garantir que a segurança seja uma prioridade estratégica alinhada com os objetivos e valores da organização.

Centralizado vs. descentralizado

Os modelos de governança de segurança centralizados e descentralizados têm como objetivo alcançar as metas de segurança da organização, proteger ativos, reduzir riscos e garantir a conformidade regulatória. Além disso, eles reconhecem a importância da segurança e a necessidade de colaboração entre as partes interessadas e os departamentos. No entanto, existem diferenças notáveis entre as duas abordagens. Na governança de segurança centralizada a autoridade da tomada de decisão depende principalmente de um único grupo ou departamento central que estabelece políticas, procedimentos e diretrizes e toma decisões importantes que giram em torno da segurança. A alocação de recursos, incluindo orçamento e pessoal, é controlada por esse grupo para promover uniformidade e padronização em toda a organização.

Por outro lado, a governança de segurança descentralizada distribui a autoridade da tomada de decisão para diferentes grupos ou departamentos de modo a facilitar as decisões relacionadas à segurança com base nas necessidades e prioridades locais. Cada unidade tem maior controle sobre a alocação de recursos de segurança para permitir maior adaptabilidade e adequação das competências de segurança.

A escolha entre governança de segurança centralizada e descentralizada depende do porte, da estrutura, da cultura e da tolerância ao risco da organização. Em última análise, o objetivo é criar um modelo de governança de segurança que ampare de forma eficaz as necessidades da organização e, ao mesmo tempo, equilibre os riscos de segurança.

Nota:

As estruturas de governança híbrida combinam elementos de abordagens centralizadas e descentralizadas. O objetivo é equilibrar as vantagens da supervisão centralizada e da implementação descentralizada. Em um sistema híbrido, determinados processos e decisões de segurança são centralizados, enquanto outros são delegados a unidades de negócios ou departamentos para facilitar o desenvolvimento de políticas corporativas padronizadas, proporcionando flexibilidade e controle local conforme necessário.

Comitês e conselhos

Os conselhos de governança dependem de [[comitês de governança]] para auxiliar em situações de tomada de decisão complexas. O conselho de governança é geralmente composto por executivos com a autoridade máxima de tomada de decisão e é responsável por definir a direção estratégica e as políticas da organização. Essa responsabilidade geralmente exige que os executivos tomem decisões críticas sobre assuntos fora de seu escopo de especialização.

Os comitês são grupos especializados compostos por especialistas no assunto, partes interessadas e representantes de departamentos relevantes que se concentram em questões específicas, como segurança, gestão de riscos, auditoria ou conformidade. Eles fornecem análise aprofundada, recomendações e suporte operacional ao conselho de governança de modo a fornecer as informações essenciais necessárias para tomar decisões eficazes.

Nota:

Os conselhos de governança e os comitês de governança desempenham funções distintas dentro da estrutura de governança de uma organização. Os conselhos de governança são geralmente compostos por executivos de alto nível e partes interessadas externas, enquanto os comitês de governança são comumente compostos por especialistas no assunto e líderes operacionais.

Entidades e grupos governamentais

No âmbito governamental, os comitês de governança são frequentemente representados por agências especializadas.

Há um número de agências governamentais associadas à governança de segurança, que diferem entre países e jurisdições. Alguns exemplos de agências governamentais com responsabilidades de governança de segurança são:

Agência	Descrição
Agências reguladoras	As agências reguladoras estabelecem e fazem cumprir padrões, regulamentos e diretrizes de segurança. Elas supervisionam o cumprimento das leis relacionadas a setores específicos, como financeiro, de saúde, de telecomunicações e de energia.
Agências de inteligência	As agências de inteligência coletam e analisam informações para identificar e neutralizar possíveis ameaças à segurança e fornecem essas informações a grupos governamentais de âmbito nacional de modo a orientar a política nacional e as estratégias militares.
Agências de aplicação da lei	As agências de aplicação da lei fazem cumprir leis e regulamentos relacionados à segurança pública. Elas investigam e processam atividades criminosas, incluindo crimes cibernéticos e atividades terroristas.
Organizações militares e de defesa	As organizações militares e de defesa são responsáveis por salvaguardar a segurança nacional e proteger o país contra ameaças externas. Elas desenvolvem estratégias, políticas e recursos para lidar com a segurança física, o controle de fronteiras e a segurança cibernética relacionada à defesa.
Autoridades de proteção de dados	As autoridades de proteção de dados se concentram na proteção de dados pessoais e nos direitos de privacidade. Elas fazem cumprir os regulamentos de proteção de dados e orientam quanto às práticas recomendadas para proteger informações pessoais.
Agências de cibersegurança de âmbito nacional	As agências de cibersegurança de âmbito nacional se concentram na proteção de infraestruturas essenciais, redes governamentais e interesses nacionais de segurança cibernética. Elas desenvolvem estratégias de segurança cibernética, coordenam a resposta a incidentes e fornecem orientações sobre práticas de segurança cibernética para entidades governamentais e organizações privadas.

Funções da governança de dados

A governança de segurança depende muito de funções especialmente desenvolvidas e interdependentes, denominadas proprietário, controlador, processador e guardião. Cada função carrega responsabilidades únicas que contribuem para manter uma supervisão e controle de segurança eficazes.

[[Responsável (Owner)]]: Um colaborador de alto nível, como um diretor ou vice-presidente, normalmente exerce o papel de responsável e é, em última instância, responsável por garantir a proteção adequada dos dados. O proprietário identifica o nível de classificação e confidencialidade dos dados, decide quem deve ter acesso a eles e qual nível de segurança deve ser aplicado. Em relação à governança, o proprietário fornece orientação estratégica para garantir que as políticas de segurança se alinhem aos objetivos do negócio.

[[Controlador (Controller)]]: O papel de controlador está diretamente relacionado ao GDPR e determina as finalidades, condições e meios do tratamento de dados pessoais. Um indivíduo, autoridade pública, agência ou outro órgão pode preencher a função de controlador. O controlador garante que as atividades de processamento de dados cumpram todos os requisitos legais. Em relação à governança, o controlador ajuda a manter a conformidade legal e regulamentar.

[[Processador (Processor)]]: O processador é responsável por tratar os dados pessoais em nome do controlador, frequentemente representando provedores de serviços em nuvem (CSP), mas também podendo ser representado por fornecedores e parceiros de negócios. Os processadores devem manter registros de suas atividades de processamento, cooperar com as autoridades supervisoras e implementar medidas de segurança apropriadas para proteger os dados que manipulam. Em relação à governança, a função do processador garante que os dados sejam tratados com segurança e de acordo com as regras estabelecidas pelas funções do proprietário e do controlador.

[[Custodiante (Custodian)]]: O custodiante, também conhecido como data steward, é responsável pela guarda segura, transporte, armazenamento dos dados e pela implementação das regras de negócios. O departamento de TI geralmente representa a função de guardião e, em relação à governança, a função de guardião implementa e aplica os controles de segurança estabelecidos pelo proprietário e controlador de dados e relata os problemas indicativos de um incidente de segurança.

Nota:

A coordenação entre o proprietário, o controlador, o processador e o guardião dos dados na gestão e na proteção dos dados é fundamental para garantir a conformidade com os regulamentos de proteção de dados, estabelecer responsabilidades claras e manter a integridade e a segurança dos dados.



Resumo

A governança de cibersegurança é o mecanismo que garante que a organização cumpra leis e regulamentos, traduzindo obrigações jurídicas complexas em controles operacionais e técnicos. Sem governança, a segurança é apenas um conjunto de ferramentas isoladas; com a governança, ela se torna uma estratégia de proteção do negócio.

Aqui está a estruturação exata e inegociável deste processo:

1. Estruturas de Tomada de Decisão

- **Conselhos de Governança:** Formados por executivos de alto nível. Eles não configuram sistemas. Sua função é ditar a estratégia, o orçamento e a tolerância ao risco da organização.
- **Comitês de Governança:** Formados por especialistas técnicos (como você). Eles realizam as análises profundas de risco e conformidade para embasar as decisões dos conselhos.

2. Modelos de Autoridade

- **Centralizada:** Um núcleo central toma todas as decisões de segurança e controla o orçamento. Garante padronização absoluta, mas perde em agilidade.
- **Descentralizada:** Cada departamento cuida da própria segurança. É ágil, mas gera inconsistências arquitetônicas.
- **Híbrida:** O modelo mais eficaz. Centraliza as políticas globais e descentraliza a execução operacional para as unidades.

3. Papéis Técnicos na Governança de Dados

Se ocorrer um vazamento de dados, a responsabilidade será avaliada estritamente sob estes quatro papéis:

- **Proprietário (Owner):** Geralmente um executivo (Diretor/VP). Ele tem a responsabilidade final pelo dado. É ele quem classifica a informação (ex: Nível Restrito) e decide quem tem a autorização para acessá-la.
- **Controlador (Controller):** Entidade que determina o propósito ("por que") e os meios do processamento dos dados, garantindo a base legal da coleta.
- **Processador (Processor):** O agente que trata os dados em nome do controlador. Um provedor de nuvem que hospeda o banco de dados é um processador.
- **Custodiante (Custodian):** A equipe de TI e segurança. Implementa as regras técnicas (backups, listas de controle de acesso, criptografia) estritamente conforme ordenado pelo Proprietário e pelo Controlador.

Exemplo Prático

Imagine uma indústria química que adota sensores biométricos nos capacetes de seus engenheiros para monitorar níveis de oxigenação e evitar desmaios em áreas de risco.

- O **Controlador** é a própria indústria química, que estabelece que o propósito da coleta é exclusivamente a saúde ocupacional.
- O **Proprietário** dos dados é o Diretor de Recursos Humanos, que define que esses dados são altamente sensíveis e só podem ser vistos pela equipe médica da fábrica.
- O **Processador** é a Microsoft (Azure), onde o banco de dados da aplicação está hospedado. A Microsoft deve garantir a segurança física de seus data centers.
- O **Custodiante** é você (a equipe de Segurança da Informação). Você configura o banco de dados na Azure, aplica criptografia AES-256 e cria a restrição lógica para que apenas os IPs da sala médica acessem as informações.

A gestão de mudanças é uma estratégia sistemática para gerir todas as mudanças feitas em uma infraestrutura de TI. Seu principal objetivo é minimizar os riscos e as interrupções e, ao mesmo tempo, maximizar o valor e a eficiência das mudanças organizacionais. A gestão de mudanças depende de um planejamento, teste, aprovação e implementação eficazes de várias mudanças que variam de pequenas atualizações até complexas migrações do sistema. A gestão de mudanças deve considerar os possíveis impactos e dependências de todas as mudanças propostas e exigir o desenvolvimento de planos de contingência e reversão, caso as mudanças levem a problemas imprevistos. A documentação e a comunicação adequadas também são essenciais a fim de garantir que todas as partes interessadas relevantes entendam os detalhes das mudanças propostas e suas implicações. Os programas de gestão de mudanças promovem uma progressão controlada do software e da infraestrutura de TI e contribuem para sua resiliência e estabilidade.

Objetivos abordados na prova

- 1.3 Explicar a importância dos processos de gestão de mudanças e o impacto na segurança.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A gestão de mudanças desempenha um papel vital nas operações de segurança de uma organização. Ela diz respeito a uma abordagem sistemática que gere todas as mudanças feitas em um produto ou sistema, garantindo que métodos e procedimentos sejam usados para lidar com essas mudanças de forma eficiente e eficaz. Isso ajuda a minimizar os riscos associados às mudanças, garantindo que elas não afetem negativamente a postura de segurança, a disponibilidade do serviço ou o desempenho da organização.

Uma lista não exaustiva de mudanças normalmente geridas por um programa de gestão de mudanças inclui as seguintes:

- Implantações de software
- Atualizações de sistema
- Correções (patch) de software
- Substituições ou atualizações de hardware
- Modificações de rede
- Alterações nas configurações de sistemas
- Implementações de novos produtos
- Integrações de novos softwares
- Mudanças e atualizações nos ambientes de suporte.

Se não forem geridas adequadamente, essas mudanças podem introduzir novas vulnerabilidades no sistema, interromper os serviços ou afetar negativamente o estado de conformidade da organização. Um programa robusto de gestão de mudanças permite que todas as mudanças sejam rastreadas, avaliadas, aprovadas e revisadas. Cada mudança deve incluir documentação, com detalhes que descrevam o que será alterado, as razões da mudança, possíveis impactos e um plano de reversão caso a mudança não funcione conforme planejado. Cada mudança deve estar sujeita à avaliação de risco para identificar possíveis impactos de segurança. Os profissionais apropriados devem aprovar as mudanças antes da implementação para garantir a responsabilidade e assegurar que as mudanças estejam alinhadas com as prioridades do negócio.

Após as implementações, as mudanças devem ser revisadas e auditadas de modo a garantir que tenham sido concluídas corretamente e alcançado o resultado declarado sem comprometer a segurança. A gestão sistemática de mudanças ampara a capacidade de uma organização de reduzir o tempo de inatividade inesperado e as vulnerabilidades do sistema. Os programas de gestão de mudanças contribuem para a resiliência operacional ao garantir que as mudanças apoiem os objetivos de negócios sem comprometer a segurança ou a conformidade.

Nota:

Um processo típico de aprovação de gestão de mudanças envolve várias etapas que são criadas para garantir a avaliação e a aprovação adequadas das propostas de mudanças. As solicitações de mudança geralmente começam com o envio de uma solicitação de mudança (Request For Change, RFC) que descreve os detalhes da mudança proposta, incluindo sua finalidade, escopo e impacto potencial. A solicitação de mudança é revisada por um gerente ou comitê de mudança designado que avalia sua viabilidade, riscos, alinhamento com os objetivos organizacionais e conformidade com as políticas. Após a revisão inicial, a solicitação de mudança passa por um processo formal de aprovação que envolve as partes interessadas relevantes, como a gerência, equipes de TI e quaisquer departamentos afetados, de modo a garantir o consenso e a autorização antes que a mudança seja implementada. Ao longo do processo, a documentação e a comunicação são essenciais para acompanhar o status e o resultado das mudanças aprovadas.

Fatores que impulsionam a gestão de mudanças

A gestão de mudanças requer a experiência de indivíduos de várias partes de uma organização para supervisionar e implementar mudanças de forma eficaz. Os exemplos incluem profissionais de TI com conhecimento técnico, líderes de negócios com conhecimento operacional e diretores de conformidade com experiência jurídica. A participação desses [[stakeholders]] (que incluem qualquer pessoa com interesse direto na mudança ou no projeto que está sendo implementado ou desenvolvido) facilita uma análise abrangente das alterações propostas, ajudando a identificar riscos não evidentes e a definir planos de implementação eficazes que minimizem riscos e interrupções nos negócios. Além disso, a inclusão de partes interessadas diversificadas que tenham participado do processo de planejamento e tomada de decisão ajudar a promover a aceitação e a adoção das mudanças. A participação das partes interessadas promove a apropriação e a responsabilização, que são fundamentais para uma implementação bem-sucedida da mudança.

A propriedade na gestão de mudanças refere-se a indivíduos ou grupos que são os principais responsáveis pela implementação de uma mudança específica. Os proprietários podem ser gerentes de projeto, líderes de equipe ou qualquer pessoa responsável pela mudança. Os proprietários são responsáveis por garantir que a mudança seja implementada conforme o planejado, que os riscos sejam geridos de forma eficaz e que haja um plano claro de comunicação e treinamento associado à mudança. Eles também garantem que todas as partes interessadas revisem e aprovelem adequadamente a mudança proposta. As partes interessadas no processo de gestão de mudanças descrevem os indivíduos ou grupos afetados (ou interessados) na mudança e incluem funcionários, gerentes, o comitê de mudanças (Change Advisory Board, CAB) e, às vezes, até clientes, fornecedores e parceiros. O envolvimento das partes interessadas é fundamental para a gestão de mudanças bem-sucedida, porque manter as partes interessadas informadas sobre as mudanças, entender suas preocupações e atender às suas necessidades melhora a probabilidade de a mudança ser aceita e implementada sem conflitos desnecessários.

Conceitos de gestão de mudanças

Conceito	Descrição
Análise do impacto	É o processo de identificar e avaliar as implicações possíveis de uma mudança proposta, incluindo como a mudança afetará usuários individuais, processos de negócios ou sistemas interconectados.
Resultados dos testes	Antes da implementação, as mudanças devem primeiro ser avaliadas em um ambiente de teste para garantir que funcionem conforme o pretendido e não causem problemas. Os resultados dos testes fornecem informações valiosas sobre a probabilidade de sucesso e ajudam a identificar possíveis problemas sem afetar as operações de negócios.
Planos de reversão	Um plano de reversão ou backout é um plano de contingência para reverter alterações e devolver os sistemas e o software ao seu estado original se o plano de implementação falhar. Um plano bem definido ajuda a minimizar o tempo de inatividade e reduz o risco de perda de dados ou outros impactos graves.
Janelas de manutenção	Uma janela de manutenção é um período de tempo predefinido e recorrente para implementar mudanças. As janelas de manutenção geralmente são agendadas para períodos de baixa atividade para minimizar interrupções nos negócios.

Conceito

Descrição

Procedimentos operacionais padrão

Procedimentos operacionais padrão (Standard Operating Procedures, SOP) são instruções detalhadas e escritas que descrevem como realizar operações ou mudanças de rotina. Na gestão de mudanças, os SOPs garantem que as alterações sejam implementadas de maneira uniforme e eficaz. Normalmente são desenvolvidos durante as fases de teste e fornecem etapas detalhadas para os funcionários encarregados de implementar uma mudança de modo a contribuir para a redução de erros.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Resumo

Vamos explorar a gestão de mudanças e como ela se aplica na prática. Farei perguntas ao longo do caminho para guiar nosso entendimento técnico.

Resumo: A Mecânica da Gestão de Mudanças

A gestão de mudanças é uma abordagem sistemática e rigorosa para rastrear, avaliar, aprovar e revisar qualquer alteração na infraestrutura de segurança ou de TI. O objetivo central é absoluto: garantir que modificações, como implementações de software, patches ou atualizações de hardware, apoiem o negócio sem introduzir vulnerabilidades e sem causar tempo de inatividade não planejado.

O processo se sustenta na segregação clara de responsabilidades:

- **Proprietários:** São os responsáveis técnicos e operacionais por executar a mudança de forma controlada.
- **Partes Interessadas e Comitê de Mudanças (CAB):** Indivíduos afetados pela alteração e especialistas (TI, governança, negócios) que revisam a Solicitação de Mudança (RFC) para aprovar ou rejeitar a ação, garantindo uma avaliação de risco multidisciplinar.

Explicação Prática

Para materializar os conceitos, imagine a substituição do firewall de borda em uma instituição financeira. A mudança ou está certa, e o banco continua operando, ou está errada, e as transações são interrompidas.

- **Análise do impacto:** A equipe técnica identifica previamente que a substituição afetará a comunicação do banco de dados com os caixas eletrônicos por um curto período.
- **Resultados dos testes:** O novo modelo de firewall é validado em um ambiente de homologação (laboratório) isolado. O tráfego simulado garante que as regras de segurança funcionam sem bloquear o tráfego financeiro legítimo.
- **Janelas de manutenção:** A equipe agenda a troca física e a virada do roteamento estritamente para domingo, entre 2h e 4h da manhã, o período de menor volume transacional.
- **Procedimentos operacionais padrão (SOP):** O engenheiro não improvisa. Ele segue um roteiro escrito e testado que detalha linha por linha quais comandos de configuração executar e quais cabos migrar.
- **Planos de reversão:** Se, às 3h30 da manhã, o novo firewall começar a descartar pacotes de transações criptografadas, a equipe aborta a operação. Eles seguem o plano de contingência para religar o firewall antigo imediatamente, restaurando a rede ao seu estado exato e seguro de antes da tentativa.

As listas de permissões e de proibições desempenham um papel significativo nas práticas de gestão de mudanças e podem fazer referência a dois pontos de vista diferentes. Um cenário observa as allow lists e block lists em relação aos tipos de alteração ou sob uma perspectiva diferente.

Listas de permissão e de proibição descrevem estratégias de restrição de software desenvolvidas para controlar softwares de computador. Em termos de gestão de mudanças, uma lista de mudanças descreve uma lista de softwares, hardwares e tipos de mudanças específicos aprovados (como mudanças de rotina ou de baixo risco) que não precisam passar por todo o processo de gestão de mudanças. Uma lista de permissões também pode incluir indivíduos específicos com autoridade de aprovação para a gestão de mudanças. As listas de permissões ajudam a agilizar a gestão de mudanças reduzindo o tempo e o esforço necessários para implementar mudanças confiáveis ou pré-autorizadas. As listas de permissões devem ser atualizadas por meio de revisões regulares para garantir que permaneçam corretas em função das mudanças nas necessidades organizacionais.

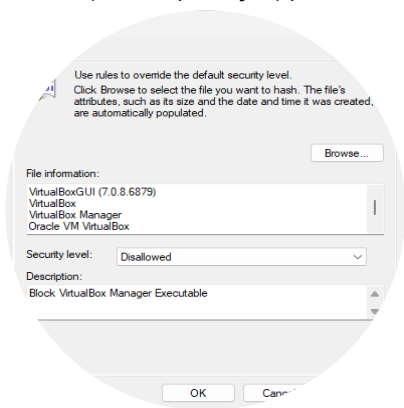
Uma lista de proibição inclui explicitamente software, hardware e tipos de mudanças específicos que foram bloqueados.

A lista de bloqueios pode incluir software e hardware com problemas conhecidos de segurança ou compatibilidade, mudanças de alto risco ou impacto que devem sempre passar por todo o processo de gestão de mudanças ou indivíduos que não estão autorizados a implementar ou aprovar mudanças. Nesse sentido, as listas de proibição ajudam a impedir a implementação de mudanças não autorizadas ou arriscadas. Elas podem servir como medida de segurança para identificar claramente os tipos de mudanças inaceitáveis, de modo a que não haja espaço para negociação ou má interpretação.

As listas de permissão e proibição também se referem aos controles técnicos existentes em determinados contextos, incluindo controles de acesso, regras de firewall e mecanismos de restrição de software. As listas de permissão e proibição podem afetar a implementação de mudanças ao causar problemas não intencionais. Por exemplo, as listas de permissões de software podem ser afetadas negativamente pela aplicação de patches de software. Se as listas de permissões forem baseadas em valores de hash de arquivos executáveis, elas não reconhecerão os executáveis com correções recentes após a aplicação destas, pois seus valores de hash terão sido alterados. Isso pode resultar em

sistemas perfeitamente corrigidos e atuais que não podem ser utilizados pelos funcionários porque os softwares, que anteriormente eram permitidos, agora não podem ser executados. Em relação à gestão de mudanças, é importante incorporar os possíveis impactos das listas de permissão e proibição ao plano de teste.

Figura 1. As políticas de restrição de software (lista de proibição) podem se basear em valores de hash de arquivo.



Captura de tela usada com permissão da Microsoft.

Descrição

A guia geral está selecionada. Algumas linhas de texto são seguidas por um botão de navegação (browse) à direita. As informações do arquivo, o nível de segurança e a descrição são exibidos abaixo. Três botões — OK, Cancelar e Aplicar — estão presentes no canto inferior direito.

Nota:

Atividades restritas referem-se a ações ou mudanças que exigem escrutínio adicional, controles rigorosos ou níveis mais altos de aprovação/autorização devido ao seu possível impacto em sistemas vitais, dados confidenciais ou conformidade regulatória.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Resumo

Aqui está o resumo técnico e a explicação prática do texto, estruturados de forma direta e rigorosa.

Resumo Técnico

O texto aborda a aplicação de listas de permissão (allow lists) e listas de proibição (block lists) sob duas óticas dentro da segurança da informação: a governança (gestão de mudanças) e a aplicação técnica (controles de segurança).

1. Perspectiva de Governança (Gestão de Mudanças):

- **Listas de Permissão:** Funcionam como um mecanismo de "via rápida". Elas contêm hardwares, softwares, tipos de mudanças de baixo risco e indivíduos pré-aprovados. Isso otimiza o tempo da equipe, pois essas mudanças não precisam passar por um conselho de aprovação longo.
- **Listas de Proibição:** Definem limites inegociáveis. Listam softwares/hardwares vulneráveis ou mudanças de alto risco que são terminantemente proibidas ou que exigem escrutínio máximo e aprovação formal. Não há margem para interpretação.

2. Perspectiva Técnica e o Risco Operacional:

- Tecnicamente, essas listas controlam o que é executado no sistema. O texto destaca um ponto crítico de falha: a atualização de softwares permitidos.
- Se uma lista de permissão baseia-se no valor de hash (uma assinatura digital única) de um arquivo executável, qualquer atualização (patch) aplicada a esse arquivo alterará o seu hash.
- Se a gestão de mudanças não prever a atualização desse hash na lista de permissão, o software legítimo e atualizado será bloqueado, causando interrupção dos serviços.

Explicação Prática

Para ilustrar de forma clara, vamos analisar um cenário prático em uma rede corporativa que utiliza controle de execução de aplicativos baseado em hash.

O Cenário:

A sua empresa utiliza um software de criptografia de discos chamado "CriptoX versão 2.0".

- **A Lista de Permissão:** A equipe de segurança extraiu o hash do executável do CriptoX 2.0 e o inseriu na lista de permissão do antivírus corporativo. Todos os computadores rodam o software perfeitamente.
- **A Lista de Proibição:** Ferramentas de mineração de criptomoedas estão configuradas na lista de proibição. Se o sistema detecta a tentativa de execução, o processo é encerrado na hora.

A Gestão de Mudança na Prática:

O fabricante do "CriptoX" lança uma atualização crítica de segurança (versão 2.1). A equipe de TI, visando manter a segurança, aprova a mudança e distribui o patch para os computadores durante a madrugada.

O Erro Rigoroso:

A equipe de TI atualizou o software, mas não atualizou a Lista de Permissão com o novo hash do "CriptoX 2.1".

Na manhã seguinte, quando os funcionários ligam seus computadores, o antivírus verifica o hash do novo CriptoX 2.1. Como esse novo hash não está na lista de permissão, o antivírus bloqueia a execução do software de criptografia em toda a empresa. Os funcionários ficam impedidos de acessar seus arquivos.

A Lição de Cibersegurança:

A segurança da informação é binária neste aspecto: ou o plano de testes da gestão de mudanças inclui a validação e atualização dos controles técnicos (como a renovação dos hashes nas listas de permissão), ou a mudança causará indisponibilidade. O sistema fez exatamente o que foi configurado para fazer: bloquear tudo o que não era explicitamente permitido.

As reinicializações de serviços e aplicativos, bem como o tempo de inatividade, são considerações fundamentais porque normalmente têm um impacto direto nas operações de negócios. Por exemplo, as reconfigurações e alterações de patches ou correções geralmente exigem a reinicialização dos serviços ou aplicativos, levando a um tempo de inatividade. Um dos principais objetivos da gestão de mudanças é minimizar essas interrupções ao agendar reinicializações ou eventos ocasionadores de improdutividade durante as janelas de manutenção ou fora dos horários de pico para reduzir o impacto nos usuários e nos processos de negócios.

Os processos de gestão de mudanças incluem requisitos de comunicação desenvolvidos para garantir que as partes interessadas relevantes estejam cientes das interrupções de serviço para que possam se preparar adequadamente. A comunicação eficaz de mudanças aumenta a visibilidade do processo de gestão de mudanças entre as partes interessadas e promove uma cultura de transparência e cooperação.

Os serviços e aplicativos geralmente dependem de outros softwares, interfaces e serviços para funcionar corretamente.

Essas [[dependências]] dificultam alterações, pois a reinicialização de um serviço em uma área pode impactar significativamente outra. Por exemplo, se um servidor de banco de dados for reinicializado, todos os aplicativos que dependem do banco de dados provavelmente terão problemas ou ficarão inativos por um tempo. Uma mudança que inicialmente parecia pequena pode afetar diversas operações da organização. Uma análise cuidadosa das dependências do software e do sistema é fundamental por razões como essas. Entender quais serviços são dependentes entre si, como as reinicializações os afetam e quais medidas precisam ser tomadas para reduzir possíveis impactos ajuda a evitar interrupções não intencionais.

As dependências também afetam o tempo necessário para uma mudança. Se a reinicialização de um serviço exigir que outros serviços sejam desligados ou reinicializados, o processo geral da mudança precisará de mais tempo. Além disso, os planos de reversão (backout) também podem precisar considerar as dependências como parte do processo, o que também exigirá tempo adicional.

Compreender os riscos associados às reinicializações e ao tempo de inatividade leva ao desenvolvimento de planos de reversão e contingências para o tempo de inatividade eficazes, garantindo que a organização esteja bem preparada para lidar com possíveis complicações e consequências não intencionais relacionadas à mudança. Além disso, compreender os riscos associados a uma mudança também contribui para desenvolver um monitoramento de desempenho pós-mudança que valide o adequado funcionamento dos sistemas e ajude a detectar problemas com rapidez. Por vezes, o risco potencial de uma mudança causar um transtorno significativo exige que a organização identifique soluções alternativas.

Algumas mudanças típicas de TI que geralmente exigem reinicializações de serviços ou aplicativos e resultam em tempo de inatividade são as seguintes:

Tipo de mudança	Descrição
Atualizações e correções de software	Ao atualizar aplicativos de software, especialmente com atualizações ou correções (patch) em versões que introduzem mudanças significativas, geralmente é necessário reinicializar o aplicativo para aplicar as alterações de forma eficaz e garantir que a versão atualizada esteja totalmente funcional.
Alterações de configuração	Muitas mudanças de configuração sistêmica, como a modificação de configurações de servidores, configurações de redes ou parâmetros de bancos de dados, exigem uma reinicialização dos serviços afetados para aplicar as configurações alteradas corretamente.
Alterações de infraestrutura	Ao alterar componentes de infraestrutura, como switches, roteadores, firewalls e balanceadores de carga, geralmente é necessário reiniciar os dispositivos para aplicar as mudanças e garantir que não causem impacto negativo nas operações.
Alterações de segurança	A implementação de medidas de segurança específicas, como atualização de protocolos de criptografia, ativação ou desativação de recursos de segurança ou modificação das configurações de controle de acesso, pode exigir a reinicialização dos aplicativos ou serviços para aplicar as novas configurações de segurança de forma eficaz.

Nota:

Tempo de inatividade refere-se ao período programado para implementar as alterações (tempo de inatividade programado) ou ao período em que um serviço ou aplicativo fica indisponível (tempo de inatividade não programado).

Sistemas e aplicativos legados

Os aplicativos legados trazem desafios singulares em relação à gestão de mudanças, pois esses sistemas geralmente são críticos para as operações de negócios e difíceis de gerenciar. Muitos aplicativos legados foram desenvolvidos com tecnologias obsoletas, gerando problemas de compatibilidade ao implementar mudanças. Por exemplo, novos softwares ou atualizações de segurança podem ser incompatíveis com sistemas legados. Para resolver isso, podem ser necessárias soluções especializadas, como virtualização, emulação, interpretadores, software personalizado de análise de lacunas (“fit gap”) ou alterações nos componentes mais recentes para garantir a compatibilidade. Essas adaptações complicam ainda mais a capacidade de gerenciamento do aplicativo legado.

Muitas vezes, os aplicativos legados não possuem uma documentação abrangente ou foram bastante personalizados ao longo de anos, ou até mesmo décadas, tornando-os extremamente difíceis de gerenciar. Essa complexidade requer testes extensos e planos de implementação meticulosos para ajudar a evitar consequências ou interrupções indesejadas. Além disso, os aplicativos legados geralmente não têm suporte do fornecedor, tirando a possibilidade de pedir ajuda, o que aumenta os riscos associados a qualquer mudança. A falta de suporte do fornecedor, bem como a alta complexidade, pouca documentação e a criticidade dos negócios, tornam os sistemas legados um problema de segurança significativo.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Resumo

Vamos direto ao ponto. Na cibersegurança, o planejamento de mudanças é exato: ou o sistema permanece seguro e disponível, ou a operação falha. Conduzirei esta explicação de forma técnica e farei perguntas ao final para guiar seu raciocínio.

Resumo Técnico da Gestão de Mudanças

- **Objetivo Principal:** Minimizar interrupções nos processos de negócios ao agendar reinicializações e períodos de inatividade exclusivamente para janelas de manutenção.
- **Comunicação:** É um requisito inegociável alertar as partes interessadas para promover transparência e permitir a preparação adequada frente a interrupções.
- **Análise de Dependências:** Softwares e serviços estão interligados; a reinicialização de um único componente pode indisponibilizar múltiplos sistemas dependentes, aumentando o tempo total necessário para a mudança.
- **Gestão de Riscos:** Exige a formulação rigorosa de planos de reversão (backout), medidas de contingência e monitoramento de desempenho pós-mudança.
- **Sistemas Legados:** Representam vulnerabilidades críticas, pois utilizam tecnologias obsoletas, carecem de documentação e não possuem suporte do fornecedor, frequentemente exigindo táticas de isolamento ou virtualização para manter a compatibilidade.

Exemplo Prático de Funcionamento

Cenário: Aplicação de um *patch* crítico de segurança no servidor de banco de dados de um sistema hospitalar.

1. **Mapeamento:** A equipe técnica identifica que o sistema de triagem de pacientes depende diretamente desse banco de dados.
2. **Agendamento:** A mudança é programada para o horário de menor fluxo (ex: 02h00). A equipe médica e os gestores são comunicados formalmente.

3. **Execução e Validação:** O serviço de banco de dados é interrompido, o *patch* é instalado e o servidor é reiniciado.

4. **Plano de Reversão:** Se, após a reinicialização, o sistema de triagem não conseguir se reconectar ao banco de dados, a equipe aborta a atualização e restaura o *snapshot* do servidor imediatamente, garantindo que a operação retorne ao estado funcional antes do fim da janela de manutenção.

O [[controle de versão]] refere-se ao acompanhamento e à gestão de alterações em documentos, códigos ou outros dados importantes. As organizações podem usar o controle de versão para manter um registro histórico das alterações, garantir que apenas as alterações aprovadas sejam implementadas e reverter rapidamente as alterações para uma versão anterior, conforme necessário. O controle de versão também é importante quando diagramas, políticas e procedimentos precisam de atualizações. Dessa forma, o controle de versão evita confusões relacionadas ao uso de documentos desatualizados ou inconsistentes.

É essencial avaliar como uma mudança afeta as políticas, procedimentos e diagramas existentes. Além disso, os planos de gestão de mudanças devem incluir disposições que exijam a atualização desses documentos como parte da implementação. A frequência de atualização de diagramas e documentações varia, mas geralmente é realizada sempre que ocorrem alterações ou modificações significativas em um processo, sistema ou aplicativo. Quando as atualizações dos documentos forem concluídas, as novas versões devem ser claramente identificadas e as versões mais antigas devem ser arquivadas, mas ainda permanecer disponíveis para consulta. Grandes mudanças podem exigir treinamento das equipes ou departamentos relevantes.

Nota:

A gestão de mudanças é um aspecto fundamental da implementação de mudanças em um sistema ou aplicativo. Ao avaliar as possíveis implicações técnicas dessas mudanças, as empresas podem tomar as medidas necessárias para minimizar as interrupções. Para gerir mudanças de modo eficaz, é preciso seguir processos específicos, como desenvolver planos de implementação e realizar procedimentos completos de teste. Por meio da gestão de mudanças, a liderança pode garantir que todas as mudanças sejam bem-sucedidas e contribuam positivamente para a organização.

Estes são alguns exemplos de documentações afetadas pela gestão de mudanças:

Item	Descrição
Solicitações de alteração	As próprias solicitações de alteração devem ser revisadas e atualizadas para refletir os detalhes e o status da alteração, incluindo quaisquer modificações ou aprovações durante o processo de gestão de mudanças.
Políticas e procedimentos	As mudanças podem afetar as políticas e procedimentos existentes. Por isso, esses documentos precisam ser revisados e atualizados para que fiquem alinhados com os novos processos, diretrizes ou controles introduzidos por meio da mudança.
Documentação do sistema ou processo	A documentação deve registrar quaisquer alterações nos sistemas, aplicativos ou processos. Isso pode envolver a atualização da arquitetura do sistema, diagramas, fluxos de processo, procedimentos operacionais padrão (Standard Operating Procedures, SOP) ou manuais do usuário para representar o estado atual e a funcionalidade do sistema alterado.

Item	Descrição
Documentação de gerenciamento de configurações	As alterações nos itens de configuração, como servidores, redes ou bancos de dados, devem ser rastreadas e documentadas no sistema de gerenciamento de configuração para manter um registro preciso de sua configuração.
Materiais de treinamento	As mudanças geralmente afetam os funcionários e podem demandar mais treinamento. Os materiais de treinamento existentes, como apresentações, manuais ou módulos de aprendizado em computador, devem ser revisados e atualizados conforme necessário.
Planos de resposta e recuperação de incidentes	As alterações feitas nos sistemas ou aplicativos podem exigir atualizações nos planos de resposta e recuperação de incidentes para garantir que eles considerem as configurações revisadas, novas dependências ou procedimentos de recuperação resultantes da alteração.

Nota:

As políticas e procedimentos devem ser alterados sempre que houver mudanças na tecnologia, o que ocorre com frequência!



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A automação e a orquestração são ferramentas poderosas para gerenciar operações de segurança. A automação usa software para executar tarefas repetitivas com base em regras, como monitorar ameaças, aplicar correções (patches), manter parâmetros de referência ou responder a incidentes, para melhorar a eficiência e reduzir as chances de erro humano. A orquestração aprimora a automação ao coordenar e agilizar as interações entre processos e sistemas automatizados. Ela contribui para fluxos de trabalho contínuos e integrados, principalmente em ambientes grandes e complexos com diversas ferramentas e sistemas de segurança. A automação e a orquestração também fornecem trilhas de auditoria claras que auxiliam na conformidade regulamentar e na investigação de incidentes. Embora sua implementação acarrete desafios, como complexidade, custo e a possibilidade de um ponto único de falha, o gerenciamento cauteloso dessas ferramentas pode melhorar muito a postura de segurança de uma organização.

Objetivos abordados na prova

- 4.7 Explicar a importância da automação e orquestração relacionadas a operações seguras.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A automação e os scripts tornaram-se ferramentas essenciais nas operações modernas de TI, ajudando as organizações a otimizar processos, fortalecer a segurança e aumentar a eficiência. A automação serve para aprimorar tanto a governança de segurança quanto a gestão de mudanças. Em termos de governança, a automação pode ajudar a impor políticas de segurança de forma mais consistente e eficiente, além de auxiliar no monitoramento e na geração de relatórios para fornecer informações valiosas às equipes de liderança e aos gestores de risco. Na gestão de mudanças, a automação pode reduzir o risco de erro humano, diminuir o tempo de implementação e fornecer trilhas de auditoria claras. Por exemplo, os scripts são eficazes para aplicar patches e atualizações nos sistemas de uma organização de maneira uniforme, e as ferramentas de automação podem rastrear essas alterações para análise posterior.

Capacidade

Descrição

Provisionamento

O provisionamento de usuários e recursos é uma tarefa fundamental de TI que se beneficia muito da automação e dos scripts. O provisionamento de usuários refere-se à criação, modificação ou exclusão de contas de usuário e direitos de acesso em todos os sistemas de TI. O provisionamento de recursos envolve a atribuição de recursos de TI, como servidores, armazenamento e redes, a aplicativos e usuários. A automação pode melhorar essas tarefas, reduzir o esforço manual, minimizar os erros e melhorar o tempo de resposta. A criação de scripts para essas tarefas ajuda as organizações a garantir uma implementação consistente e melhorar a conformidade.

Guardrails e grupos de segurança

Os guardrails (sistemas de proteção) e os grupos de segurança fornecem parâmetros para o gerenciamento da segurança em uma organização. Os guardrails automatizados podem monitorar e fazer cumprir a conformidade com as políticas de segurança, garantindo que atividades e comportamentos de risco sejam evitados ou sinalizados para análise. Os grupos de segurança definem quais recursos um usuário ou sistema pode acessar. Também podem ser gerenciados com mais eficiência por meio da automação, o que reduz a possibilidade de acesso não autorizado ou permissões excessivas.

Capacidade	Descrição
Emissão de tíquetes	A automação pode melhorar consideravelmente a eficiência das plataformas de tíquetes. Incidentes detectados por sistemas de monitoramento podem gerar automaticamente tíquetes de suporte. Além disso, a automação também pode encaminhar os tíquetes com base em critérios predefinidos, garantindo que eles cheguem à equipe ou pessoa certa para resolução. Os procedimentos de escalonamento automatizados também podem garantir que os problemas críticos recebam atenção imediata. Alguns exemplos são: incidentes de alto impacto, incidentes que demandam equipes especializadas ou que envolvem executivos e clientes importantes ou qualquer problema que possa violar um acordo de nível de serviço (Service Level Agreement, SLA) estabelecido.
Gerenciamento de serviços	A automação e os scripts também são ferramentas essenciais para gerenciar serviços e acessos em um ambiente de TI. Os analistas de segurança podem automatizar tarefas rotineiras, como habilitar ou desabilitar serviços, modificar direitos de acesso e manter o ciclo de vida dos recursos de TI. Assim, eles terão mais tempo para se dedicar às tarefas analíticas mais estratégicas ou complexas.
Integração e testes contínuos	Os princípios de integração e testes contínuos dependem fortemente da automação. Nesta abordagem, os desenvolvedores mesclam regularmente suas alterações à ramificação de código principal (main branch), e cada mesclagem é testada automaticamente para ajudar a detectar e até mesmo corrigir problemas de integração. Esse recurso melhora a qualidade do código, acelera os ciclos de desenvolvimento e reduz o risco de problemas de integração.
Interfaces de programação de aplicativos	As Application Programming Interfaces (APIs) permitem que diferentes sistemas de software se comuniquem e interajam, e a automação pode orquestrar essas interações, criando fluxos de trabalho contínuos e facilitando o desenvolvimento de sistemas mais complexos, como plataformas de orquestração, automação e resposta de segurança (Security Orchestration, Automation and Response, SOAR).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Benefícios da automação e orquestração em operações de segurança

A automação e a orquestração também oferecem muitos benefícios importantes para as operações de segurança. Principalmente, essas práticas aumentam a eficiência ao permitir que tarefas repetitivas sejam executadas de forma rápida e consistente, reduzindo a sobrecarga das equipes de segurança e minimizando a probabilidade de erro humano (às vezes chamado de [[multiplicadora força de trabalho]]).

A fadiga do operador se refere ao esgotamento mental que os profissionais de segurança cibernética experimentam devido à natureza contínua e de alta intensidade do seu trabalho. Os analistas de segurança devem monitorar vários sistemas em busca de possíveis ameaças, gerenciar grandes volumes de alertas (incluindo muitos falsos-positivos) e responder a ameaças confirmadas o mais rápido possível. Essas condições de trabalho geralmente levam a longas jornadas laborais, ansiedade e níveis elevados de estresse, resultando em fadiga do operador. Essa é uma preocupação importante na segurança cibernética, pois pode levar à diminuição do estado de alerta e da função cognitiva e prejudicar a capacidade do pessoal de segurança de identificar e responder a ameaças de forma eficaz. A fadiga resulta na omissão de alertas críticos, tempos de resposta mais lentos e uma maior probabilidade de erros, que podem comprometer a segurança.

A automação e a orquestração são fundamentais no combate à fadiga nas operações de segurança, pois minimizam as tarefas repetitivas e manuais que geralmente contribuem para a fadiga do operador. Elas reduzem significativamente a carga de trabalho de uma equipe de segurança ao automatizar tarefas de rotina, como procurar vulnerabilidades, aplicar patches ou monitorar sistemas em busca de atividades anômalas. Com isso, os recursos poderão ser usados com mais eficiência e o pessoal de segurança terá mais tempo para se dedicar a questões mais complexas e estratégicas que requerem discernimento e criatividade humanos. A orquestração potencializa o impacto da automação ao coordenar tarefas automatizadas entre diferentes sistemas e ferramentas de software, reduzindo os [[tempos de detecção]] e resposta.

Por exemplo, quando uma ameaça é detectada, um sistema orquestrado pode automaticamente isolar a sub-rede afetada, realizar análises e relatórios básicos, notificar as equipes de segurança, gerar tíquetes e documentar o incidente, tudo isso sem intervenção humana. Outro benefício da automação é a imposição de parâmetros de referência padronizados por meio de ferramentas de gerenciamento de configurações para substituir automaticamente modificações não autorizadas feitas nos endpoints. No gerenciamento de configurações, um parâmetro padronizado é um conjunto bem definido de configurações e definições aprovadas que serve como ponto de referência para estabelecer e manter o estado desejado de um sistema. Ao reduzir o volume de tarefas manuais e rotineiras, a automação e a orquestração podem aliviar significativamente a fadiga dos operadores, melhorando a eficiência das operações de segurança. Isso leva a maior satisfação no trabalho, a um aumento da atenção e eficácia na detecção e resposta a ameaças e, em última análise, a operações de segurança mais robustas.

Nota:

A automação pode contribuir para as iniciativas de retenção de pessoal ao reduzir a fadiga causada por tarefas repetitivas. Com as práticas de automação, os funcionários terão mais tempo para realizar um trabalho mais gratificante e sentir mais satisfação no trabalho.

Considerações importantes

Embora a automação e a orquestração ofereçam inúmeros benefícios, elas também apresentam alguns desafios significativos, por exemplo:

- **Complexidade:** a implementação de automação e orquestração requer um conhecimento aprofundado dos sistemas, processos e interdependências de uma organização. Uma estratégia de automação mal planejada ou executada pode agregar complexidade, tornando os sistemas mais difíceis de gerenciar e manter.
- **Custo:** o custo inicial da implementação de automação e orquestração pode ser alto. Isso inclui os custos associados à aquisição e desenvolvimento de ferramentas apropriadas, sua integração aos sistemas existentes e treinamento da equipe para usá-las de forma eficaz. A manutenção e as atualizações do software de automação também podem ser dispendiosas.
- **[[Ponto Único de Falha]]:** Se um sistema ou processo automatizado crítico falhar, isso pode impactar várias áreas da organização, causando problemas generalizados.
- **[[Dívida Técnica]]:** As organizações podem acumular dívida técnica se ferramentas de automação e orquestração forem implementadas de forma apressada, resultando em código mal documentado, integrações de sistemas “frágeis” ou manutenção deficiente. Com o tempo, essa dívida pode levar à instabilidade do sistema, à complexidade e ao aumento dos custos, problemas que ironicamente lembram àqueles associados a sistemas legados.
- **Suporte contínuo:** para se manterem eficazes e seguros, os sistemas de automação e orquestração necessitam de suporte contínuo, incluindo atualizações e aplicação de patches, revisão e melhoria dos processos automatizados e capacitação contínua. Sem um suporte adequado, os benefícios da automação e orquestração logo desaparecem.

Nota:

A manutenção da segurança do sistema ao adicionar novos hardwares ou itens de infraestrutura à rede pode ser alcançada por meio da aplicação de **[[configurações padrão]]** em toda a empresa. Com configurações automatizadas, os itens recém-adicionados poderão ser mantidos atualizados e seguros.

Benefícios da automação do gerenciamento de infraestrutura

A automação e a orquestração de configurações de infraestrutura trazem inúmeros benefícios. A aplicação de configurações padronizadas garante consistência e precisão em toda a infraestrutura. A automação economiza tempo e recursos, permitindo que as configurações sejam implantadas rapidamente, e também aumenta a escalabilidade e a flexibilidade ao simplificar a implantação e configuração de novos recursos.

Além disso, a automação e a orquestração melhoram a padronização, a conformidade e a gestão de mudanças ao aplicar padrões de configuração predefinidos, facilitando a auditoria e o rastreamento de alterações e controlando o desvio de configuração. A automação também pode fortalecer a segurança e a governança ao impor controles de segurança, aplicar patches de forma consistente e automatizar tarefas relacionadas à segurança.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Você deve ser capaz de identificar a importância da governança e seu papel na formação das capacidades de um programa de segurança.

Diretrizes para implementar a governança

Siga estas diretrizes para favorecer controles de governança eficazes:

- Implemente uma estrutura de governança que melhor atenda aos objetivos da organização.
- Aproveite a experiência dos participantes por meio de comitês para apoiar a tomada de decisões.
- Crie uma lista abrangente de políticas, processos, padrões e diretrizes.
- Implemente programas de gestão de mudanças para manter o controle e promover a transparência.
- Use ferramentas de automação e orquestração para melhorar a consistência, reduzir os tempos de resposta e assegurar a conformidade.



This content is only available on larger screen sizes. Please revisit this page on a larger device.